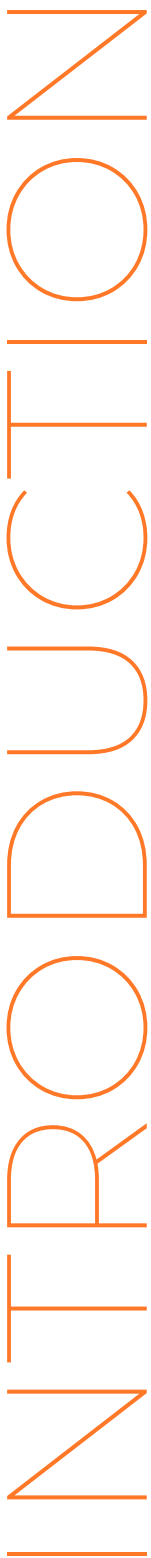

Vulnerability Assessment Report

PRANESH GANESAN



A passive, non-intrusive vulnerability assessment was conducted against the publicly accessible DemoQA web application at <https://demoqa.com/>.

The assessment focused on identifying observable web security misconfigurations, security-header weaknesses, information disclosure issues, and vulnerable third-party JavaScript components. Testing was performed using Google Chrome DevTools, Nmap, and OWASP ZAP. A total of six security findings were identified and reviewed:

- 3 Medium-severity findings
- 3 Low-severity findings

The Medium-severity findings consisted of a missing Content Security Policy, missing anti-clickjacking protection, and a potentially vulnerable DOMPurify JavaScript dependency identified by OWASP ZAP's Retire.js analysis.

The Low-severity findings consisted of web server version disclosure, X-Powered-By technology disclosure, and a missing X-Content-Type-Options security header. No exploitation, brute-force testing, authentication bypass, denial-of-service testing, or destructive activity was performed. The assessment was intentionally limited to passive and non-intrusive techniques. The findings indicate opportunities to strengthen the application's browser security controls, reduce unnecessary technology disclosure, and improve third-party dependency management.

1. ASSESSMENT OVERVIEW

Target

Application: DemoQA

URL: <https://demoqa.com/>

Assessment Type: Passive / Non-Intrusive Web
Application Assessment

Objective:

The objective of this assessment was to identify observable security weaknesses in the publicly accessible application and provide practical remediation recommendations.

The assessment primarily focused on:

- HTTP security headers
- Browser security controls
- Technology and server information disclosure
- Third-party JavaScript dependencies
- Basic network exposure
- Security configuration weaknesses

Scope:

The assessment was limited to publicly accessible resources associated with the DemoQA application. Testing was conducted without attempting to gain unauthorized access or exploit identified weaknesses.

2. METHODOLOGY

The assessment followed a passive and non-intrusive workflow.

01

Reconnaissance

Basic network reconnaissance was performed using Nmap to identify externally observable network services associated with the target.

02

Web Application Observation

The application was accessed through Google Chrome and its HTTP traffic was reviewed using Chrome DevTools.

03

Passive Security Analysis

OWASP ZAP was configured as a local proxy and used in passive mode to inspect HTTP responses generated while browsing the application.

04

Finding Validation

ZAP-generated alerts were reviewed and classified based on their relevance to the target application. Informational alerts and findings that did not represent meaningful security weaknesses were excluded from the final findings.

05

Evidence Collection

Screenshots were captured for the verified findings and supporting reconnaissance activity.

3. TESTING RESTRICTIONS

The assessment did not include:

- Exploitation
- Brute-force attacks
- Credential attacks
- Authentication bypass
- Denial-of-service testing
- Fuzzing
- Destructive testing
- Unauthorized access attempts

4. TOOLS USED

Tool	Purpose
Nmap	Basic network reconnaissance and service identification
OWASP ZAP	Passive web application security analysis
Google Chrome DevTools	HTTP request and response/header inspection

5. TECHNOLOGIES AND CONCEPTS

The assessment involved practical analysis of :

- HTTP/HTTPS
- Security response headers
- Content Security Policy
- Clickjacking protection
- MIME-sniffing protection
- Server information disclosure
- JavaScript dependency security
- Basic network reconnaissance

6. FINDINGS SUMMARY

01

Missing Content Security Policy (CSP)

Severity: MEDIUM

Confidence: HIGH

02

Missing Anti-clickjacking Header

Severity: MEDIUM

Confidence: MEDIUM

03

Vulnerable JavaScript Library — DOMPurify 3.2.6

Severity: MEDIUM

Confidence: MEDIUM

04

Server Version Information Disclosure

Severity: LOW

Confidence: HIGH

05

X-Powered-By Information Disclosure

Severity: LOW

Confidence: MEDIUM

06

X-Content-Type-Options Header Missing

Severity: LOW

Confidence: MEDIUM

SEVERITY DISTRIBUTION

Medium: 3

Low: 3

Critical: 0

High: 0

The assessment did not identify any Critical or High severity findings within the defined passive testing scope.

TESTING RESTRICTIONS

THE ASSESSMENT DID NOT INCLUDE:

- EXPLOITATION
- BRUTE-FORCE ATTACKS
- CREDENTIAL ATTACKS
- AUTHENTICATION BYPASS
- DENIAL-OF-SERVICE TESTING
- FUZZING
- DESTRUCTIVE TESTING
- UNAUTHORIZED ACCESS ATTEMPTS

7. DETAILED FINDINGS

01

Missing Content Security Policy (CSP)

Severity: MEDIUM

Confidence: HIGH

URL: <https://demoqa.com/>

Description: CSP header was not present in the HTTP response, reducing browser-side protection against certain content-injection/XSS scenarios.

Evidence: 01-CSP.png

Recommendation: Implement an appropriate Content-Security-Policy header.

02

Missing Anti-clickjacking Header

Severity: MEDIUM

Confidence: MEDIUM

URL: <https://demoqa.com/>

Description: No X-Frame-Options or equivalent frame-ancestors protection was observed.

Evidence: 02-Anti-Clickjacking.png

Recommendation: Implement X-Frame-Options: SAMEORIGIN or an appropriate CSP frame-ancestors policy.

03

Vulnerable JavaScript Library — DOMPurify 3.2.6

Severity: MEDIUM

Confidence: MEDIUM

URL: <https://demoqa.com/swagger-ui-bundle.js>

Description: OWASP ZAP identified DOMPurify 3.2.6 and associated it with CVE-2026-66010 and CVE-2026-75838.

Evidence: 03-DOMPurify.png

Recommendation: Upgrade DOMPurify to a current secure release and maintain regular dependency monitoring.

04

Server Version Information Disclosure

Severity: LOW

Confidence: HIGH

URL: <https://demoqa.com/>

Evidence:

Server: nginx/1.17.10 (Ubuntu)

Impact: Reveals server technology/version information useful for reconnaissance.

Recommendation: Hide or minimize server version disclosure.

Evidence: 04-Server-Version.png

05

X-Powered-By Information Disclosure

Severity: LOW

Confidence: MEDIUM

URL: <https://demoqa.com/>

Evidence:

X-Powered-By: Express

Impact: Reveals the application's underlying framework.

Recommendation: Remove the X-Powered-By header in production.

Evidence: 05-X-Powered-By.png

06

X-Content-Type-Options Header Missing

Severity: LOW

Confidence: MEDIUM

URL: <https://demoqa.com/>

Description: The X-Content-Type-Options security header was not present.

Evidence: 06-X-Content-Type-Options.png

Recommendation: Configure:

X-Content-Type-Options: nosniff

REMEDIATION

01 : Missing CSP

Implement a strong Content-Security-Policy header and review allowed scripts, styles, and resources.

02 : Missing Anti-clickjacking Header

Add X-Frame-Options: SAMEORIGIN or configure CSP frame-ancestors.

03 : Vulnerable DOMPurify 3.2.6

Upgrade DOMPurify to the latest secure version and regularly monitor dependencies for known vulnerabilities.

04 : Server Version Disclosure

Configure the web server to hide or minimize version information in the Server header.

05 : X-Powered-By Disclosure

Remove the X-Powered-By: Express header from production responses.

06 : Missing X-Content-Type-Options

Add X-Content-Type-Options: nosniff to HTTP responses.

CONCLUSION

The passive security assessment of DemoQA identified six security findings, including missing security headers, information disclosure, and a potentially vulnerable JavaScript dependency. The findings were assessed without exploitation or intrusive testing.

Addressing the identified issues, particularly CSP, anti-clickjacking protection, and the DOM Purify dependency would improve the application's overall security posture. This assessment demonstrates the use of industry-standard tools and security assessment practices while maintaining a non-intrusive testing approach.
